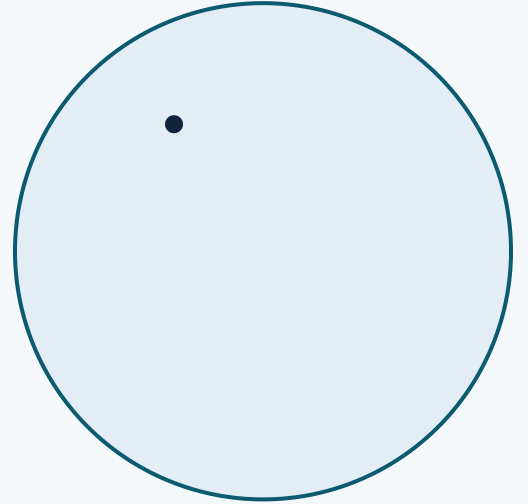


Verifier Reference Implementation

From content provenance to verifiable trust decisions

Unreleased · post-v0.19.0



Signatures are necessary. They're not sufficient.



A signature proves signing, not authorization

A valid CAWG/C2PA signature shows the manifest was signed — it does not show the actor was authorized to act.



Decisions must be replayable

Auditors and appeals need to reproduce a verification decision from pinned evidence after the fact, not just trust a log line.



Policy is separate from content

Provenance and governance policy live in different systems; without a machine-readable link, enforcement is manual and inconsistent.



Multi-registry environments are the norm

Federated registries, gateways, and offline snapshots create routing ambiguity and siloed trust unless a common protocol binds them.

CAWG/C2PA and TRQP answer different questions.

The reference implementation sits at the seam between content-authenticity evidence and governed authorization — it does not extend or reinterpret either specification.

CAWG / C2PA

What happened to this content?

Establishes tamper-evident provenance: capture, edits, ingredients, assertions, and cryptographic integrity of the manifest chain.

TRQP

Is this actor authorized for this action?

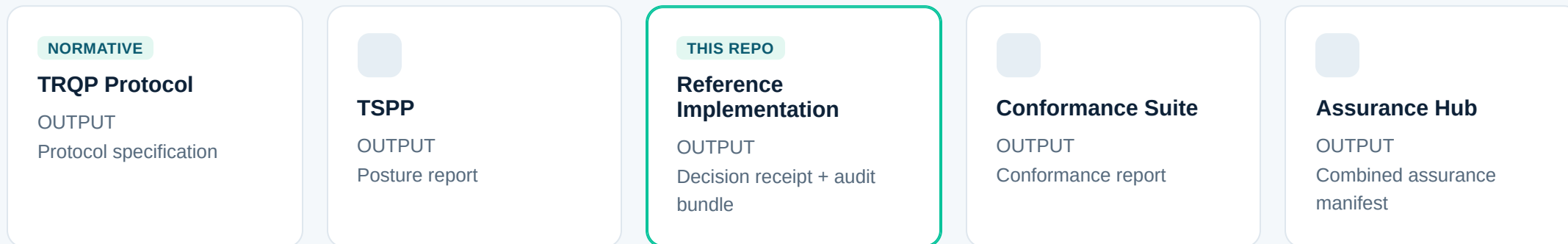
Establishes recognized authority, delegated scope, and a governed, revocable decision about whether an action may proceed.

This repository is **not** a specification. It is a repository-scoped executable reference implementation: authoritative for its own code, schemas, profiles, and fixtures, and explicitly non-authoritative for CAWG/C2PA or TRQP specification governance.

THE STACK

One protocol, accountable layers across repositories.

Authority is distributed by design — no single repository governs the whole decision.



Each layer publishes its own evidence; cross-stack use pins versions or commit SHAs into the evidence bundle. This repository is the flagship, pilot-ready reference implementation layer.

What this repository guarantees — and what it explicitly does not.



Authority & recognition

Policy feeds, trust anchors, and recognition responses establish who is recognized before any action is evaluated.



Delegation & action scope

Authorization requests, gateway routes, and context profiles bind a decision to a specific actor, action, and resource.



Enforcement & revocation

Live, delta, snapshot, and fail-closed descriptor policies keep enforcement current under partial connectivity.



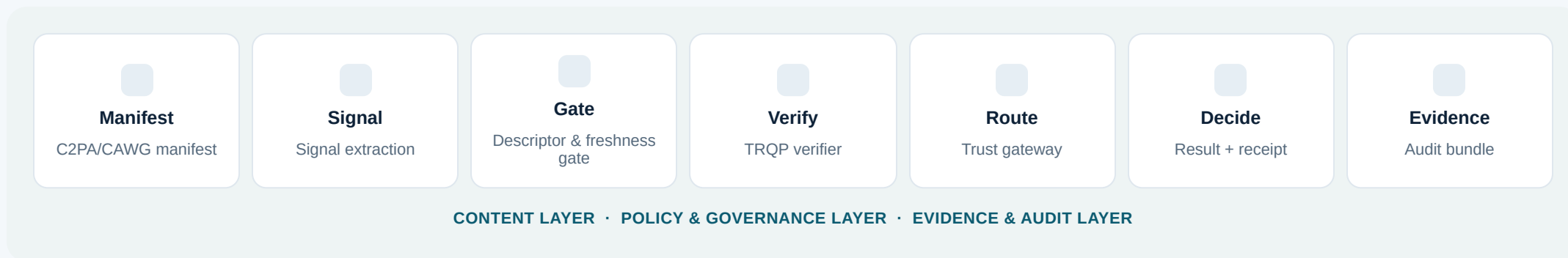
Auditability

Stable reason codes, decision receipts, and signed, replayable audit bundles make every decision reproducible.

Does not assert: production certification, independent assurance, factual truth determination, or ownership adjudication. Provenance and authorization evidence do not establish factual truth — that responsibility remains with the relying organization.

HOW IT WORKS

From manifest to verified, replayable decision.



Process appraisal is optional and layered in at the verifier stage — the gateway routes to policy services per authority_id, enabling multi-registry and federated deployments without re-architecting each verifier.

Three built-in profiles, two composable overlays.

Profiles are schema-backed and machine-selectable; overlays (evidence_attested, freshness_strict) compose onto a base profile without forking it.

PROFILE	INTENDED POSTURE	REVOCATION ENFORCEMENT	NETWORK/POLICY FAILURE	DESCRIPTOR POLICY
edge	Constrained / offline-tolerant	warn	fail_open	observe
standard	General-purpose deployment	warn	fail_open	observe
high_assurance	Regulated / evidentiary	hard_fail	fail_closed	fail

profiles/edge.json

profiles/standard.json

profiles/high_assurance.json

overlays/evidence_attested.json

overlays/freshness_strict.json

Decision receipts that survive an audit.



Proposition-level evidence

Integrity, assertion expectation, issuer recognition, authorization, process integrity, and conflict state are reported separately — never collapsed into one success flag.



Deterministic conflict handling

Explicit assertion-conflict detection with relying-party profile-local precedence rules and an explicit unresolved-conflict state.



Degraded & fail-closed states

`degraded` for warning-level semantic gaps; fail-closed `semantic\_guardrail` behavior for required evidence or conflict failures.



Signed, replayable audit bundles

Every decision can produce a signed audit bundle that replays deterministically from a trusted root — the basis for appeal and reproducibility.

Policy routing without re-architecting the verifier.

- Routes verification requests to the correct policy service by `authority_id`, supporting multi-registry and federated deployments.
- Supports **online_full**, **gateway**, and **offline_snapshot** transport modes, and **direct**, **gateway**, and **snapshot** descriptor sources.
- Gateway routes are themselves descriptor-policy governed — observe, warn, or fail on stale or untrusted routing state.
- HTTP service hardening includes structured audit events for verification and audit-bundle routes.

Why it matters

A single verifier binary can serve many trust registries and policy authorities without embedding registry-specific logic — governance stays externalized and auditable.

Agent identity is not agent authority.

A cross-cutting model, new since v0.19.0, that keeps content assurance, actor/authority assurance, and action/decision assurance separable and testable for AI agents.

ROLE	TYPICAL ACTION	ASSURANCE QUESTION
Producer	Generates or transforms content	Was this agent authorized to create or alter this artefact?
Submitter	Packages or submits evidence	Was this agent authorized by the principal to submit this resource, for this purpose?
Verifier	Resolves provenance, authority, or policy state	Was the agent authorized to verify, and are findings reproducible from pinned evidence?
Orchestrator	Calls registries, tools, verifiers, or other agents	Can the full delegated action chain be reconstructed and bounded?
Decision agent / Proxy	Recommends, executes, or acts on behalf of a principal	Is decision authority separately delegated, scoped, current, and revocable?

- Agent Role Model
- Delegation & Authority
- Verification & Decision Boundaries
- 3 executable cross-sector archetypes

One governance pattern, twenty-one executable scenarios.

21

total walkthroughs

18

sector walkthroughs, each with an Agentic AI Variant

3

cross-sector agentic archetypes

6

lifecycle states per scenario manifest

ASSURANCE PATTERN	REPRESENTATIVE WALKTHROUGHS	WHAT IT PRESSURE-TESTS
Publication & public communication	Breaking news, video, campaign advertising	Editorial/campaign authority, rapid revocation
Rights & commercial authorization	Music distribution, property listings, marketplace	Delegated rights, disclosure scope, disposition
Regulated / evidentiary intake	Insurance, medical imaging, legal evidence	Separation of intake from substantive adjudication
Field & operational evidence	Body-camera, construction, disaster response, industrial	Device/actor delegation, offline state, safety
Long-lived & correction-sensitive	Scientific imagery, cultural heritage, photo contest	Reproducibility, immutable correction
Constrained / humanitarian	Offline field evidence, warranty & repair	Intermittent connectivity, contested evidence

Governance, federation, caching, and evidence are security-critical surfaces.

THREATS & RISKS

Adversarial assurance model

Trust boundaries and assets → adversary profiles → attack surfaces → adversarial scenarios → preventive / detective / recovery controls → tested residual-risk decisions.

threat-register.yaml

adversary-catalog.yaml

abuse-case-register.yaml

residual-risk-register.yaml

PRIVACY & PERSONAL INFORMATION

Governable data handling

Minimized integration signal → verifier → minimal decision receipt (default) or privileged replay bundle (explicit scope) → controlled evidence store → human review and redress.

minimal-receipt.json

replay-bundle.json

regulated-evidence.json

Non-normative: does not assert compliance with any jurisdiction. A deployer must map controls to its own purpose, role, data, users, geography, and legal obligations.

Machine-readable review artifacts for specification and stakeholder review.

Interface review

CAWG Input Contract, API Call Catalogue, and interoperability vectors define every accepted input shape and implemented call surface.

[api/openapi.json \(OpenAPI 3.1\)](#)

Compatibility matrix

Machine-readable compatibility matrix tracks alignment across the TRQP protocol, TSPP, conformance suite, and assurance hub.

[conformance/compatibility-matrix.json](#)

Conformance evidence

Readiness matrices, risk-to-test maps, and an assurance-suite manifest let external suites ingest this implementation's evidence.

[conformance/risk-to-test-map.yaml](#)

[25 JSON Schemas](#)

Every capability claim in this deck is machine-checked.



make validate

Runs repository/documentation integrity, OpenAPI contract, JSON examples, walkthrough manifests and diagrams, agentic-assurance drift checks, and the full pytest suite.



28 test modules

Covering the verifier core, HTTP service, gateway routing, cache policy, conformance vectors, security hardening, and privacy controls.



Release checksums

scripts/generate_release_checksums.py --check produces a verifiable manifest for every tagged release asset.



Reproducibility

scripts/check_reproducibility.py and scripts/replay_audit_bundle.py replay pinned evidence against a trusted root.

What's shipped, and what remains deliberately open.

Recently landed

- Semantic assurance controls and deterministic conflict handling (v0.19.0)
- Agentic AI assurance model across the full walkthrough portfolio
- Adversarial threat model and privacy/personal-information governance package
- Scale architecture, cache-freshness, and high-volume deployment guidance

Deliberately open

- Real binary CAWG/C2PA parser backend behind the adapter boundary
- Expanded adversarial negative-vector library
- Containerized production service packaging
- Cross-repository alignment of assurance-suite and descriptor-policy controls

From clone to a verified decision in under a minute.

```
python -m venv .venv && . .venv/bin/activate
pip install -r requirements-lock.txt && pip install -e .
python -m cawg_trqp_refimpl.cli examples/verification_request.json --profile standard
python scripts/start_http_service.py --policy-path data/policies.json --host 127.0.0.1 --port 5000
make validate
```

Guided learning

[docs/guided-learning.md](#)

Non-technical overview

[docs/NON_TECHNICAL_OVERVIEW.md](#)

Contributing

[CONTRIBUTING.md](#) & [GOVERNANCE.md](#)

THANK YOU

Executable trust, not a claim about trust.

Every statement in this deck is backed by a schema, a profile, a test, or a replayable piece of evidence in the repository.

Repository

github.com/sankarshanmukhopadhyay/cawg-trqp-verifier-refimpl

Documentation site

sankarshanmukhopadhyay.github.io/cawg-trqp-verifier-refimpl

Status contract

PROJECT-STATUS.yaml &
GOVERNANCE.md